STANDAR OPERASIONAL PROSEDUR (SOP)
CAPSTONE PROJECT

1. **Standar Keamanan Aplikasi/Web**
   - Seluruh sistem wajib melalui proses penetration testing (pentest) sebelum dinyatakan layak digunakan atau diserahkan.
   - Mekanisme autentikasi wajib memiliki mitigasi terhadap brute force attack, SQL injection, dan serangan relevan lainnya.
   - Seluruh form wajib divalidasi pada frontend dan backend. Implementasi validasi harus mencakup masking input untuk mencegah karakter berbahaya dan injection.
   - Fitur upload file wajib menerapkan pembatasan ekstensi secara eksplisit pada frontend dan backend.
   - File yang bersifat sensitif atau mengandung credential tidak boleh dapat diakses langsung melalui URL. Akses file wajib dilakukan melalui controller atau mekanisme access layer yang tervalidasi.
   - Sistem wajib membatasi ukuran file maksimum dan jumlah file total yang dapat diunggah.

2. **Standar User Interface (UI)**
   - Antarmuka wajib responsif dan dapat menyesuaikan ukuran layar secara dinamis.
   - Kompatibilitas minimal mencakup desktop/laptop, smartphone, dan tablet.
   - Platform target minimal mencakup Windows, macOS, Android, dan iOS.
   - Tidak diperbolehkan terjadi layout overflow, elemen terpotong, atau komponen yang tidak terbaca pada resolusi target.
   - Sistem wajib menyediakan loading state, error state, atau feedback visual yang jelas kepada pengguna.

3. **Standar Penulisan Kode, Routing, dan Arsitektur Sistem**
   - Implementasi wajib mengikuti prinsip clean code.
   - Hardcoded value tidak diperbolehkan untuk URL, secret key, credential, role, maupun data sensitif lainnya.
   - Struktur kode harus modular, terorganisir, dan bebas dari spaghetti code.
   - Prinsip DRY (Don’t Repeat Yourself) wajib diterapkan untuk menghindari duplikasi logic yang tidak diperlukan.
   - Seluruh route harus bersifat relative atau configurable melalui base path / environment configuration.
   - Penggunaan absolute path hardcoded seperti href="/" atau fetch("/api/...") tidak diperbolehkan apabila menyebabkan ketergantungan pada root domain.
   - Aplikasi harus tetap berjalan normal ketika dijalankan di dalam subdirectory.
   - Arsitektur sistem wajib jelas dan terstruktur, misalnya MVC, Layered/N-Tier, Clean Architecture, MVVM, atau pola serupa.
   - Harus terdapat pemisahan yang tegas antara presentation layer, business logic layer, dan data access layer.

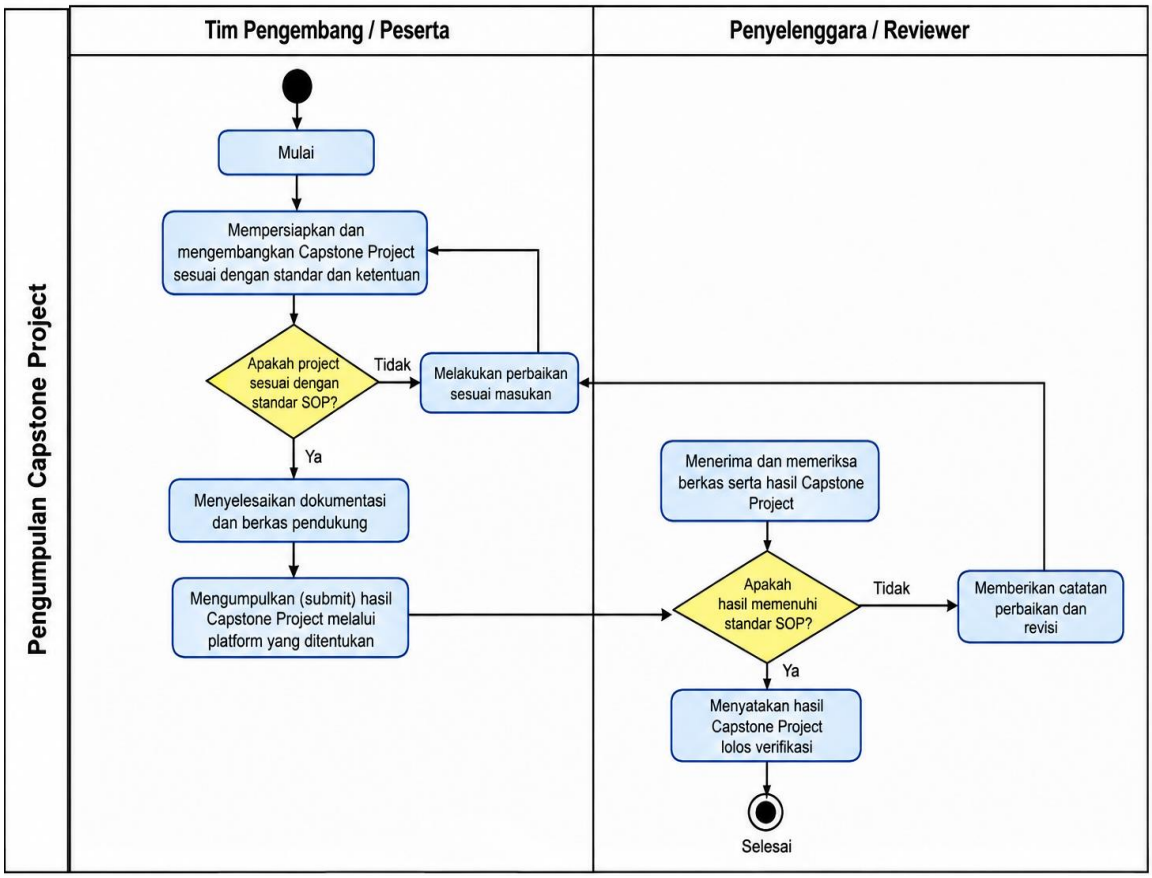
4. **Manajemen API, Environment, dan Request Handling**
   - Konfigurasi pemanggilan API harus dipusatkan dan tidak ditulis secara statis di source code.
   - Seluruh credential dan parameter sensitif wajib disimpan di file environment (.env).
   - Ukuran request/payload harus dibatasi agar sistem tetap stabil dan tidak rentan overloading.
   - Batas aman yang direkomendasikan untuk query/payload per request adalah sekitar 10 KB.
   - Payload berukuran besar, misalnya 10 MB per request, tidak diperbolehkan.

5. **Database, Query, dan CRUD**
   - Sistem wajib mendukung fungsi CRUD secara penuh, yaitu Create, Read, Update, dan Delete.
   - Skema database harus terstruktur, memiliki relasi yang valid, dan sesuai dengan kebutuhan proses bisnis.
   - Query database harus efisien dan tidak membebani engine database.
   - Penggunaan SELECT * tanpa pagination tidak diperbolehkan.
   - Pengambilan data dalam jumlah besar wajib menggunakan pagination atau pembatasan result set.
   - Implementasi query harus menjaga performa pada operasi insert, update, read, dan delete.

6. **Keamanan Data dan Credential Protection**
   - Informasi credential atau secret tidak boleh terekspos kepada end-user.
   - Password tidak boleh disimpan dalam bentuk plaintext.
   - Seluruh input dari frontend wajib divalidasi ulang di backend.
   - Data sensitif harus diproses melalui mekanisme yang aman untuk mencegah kebocoran dan eksploitasi.

7. **Testing dan Validasi**
   - Proyek direkomendasikan memiliki mekanisme pengujian yang dapat dijalankan ulang tanpa memulai proses secara manual dari awal.
   - Pengujian dapat didukung melalui script testing, API test collection, dan seeder atau dummy data.
   - Skenario testing minimal harus mencakup alur login, tambah data, edit data, hapus data, dan validasi akses.

Activity Diagram Pengumpulan Capstone


Pengumpulan Capstone Project
Tim Pengembang / Peserta
Penyelenggara / Reviewer
Mulai
Mempersiapkan dan mengembangkan Capstone Project sesuai dengan standar dan ketentuan
Apakah project sesuai dengan standar SOP?
Tidak
Melakukan perbaikan sesuai masukan
Ya
Menyelesaikan dokumentasi dan berkas pendukung
Mengumpulkan (submit) hasil Capstone Project melalui platform yang ditentukan
Menerima dan memeriksa berkas serta hasil Capstone Project
Apakah hasil memenuhi standar SOP?
Tidak
Memberikan catatan perbaikan dan revisi
Ya
Menyatakan hasil Capstone Project lolos verifikasi
Selesai